INTERNCIRCLE CYBERSECURITY TRACK • PROJECT 03

# Phishing Email Analysis & Staff Awareness Report

**Analyst:** THRIGUNA G.A | **Domain:** Email Security & Social Engineering Defense | **Specimens Analysed:** 5 (3 Phishing, 2 Genuine)

---

**Executive Overview:** This report examines five representative email specimens—three malicious social engineering lures and two legitimate organizational communications—to demonstrate practical header inspection, non-interactive URL verification, and payload indicator triage. Every specimen below has been sanitized to redact personal identifiers and annotated with numbered markers mapped to forensic findings.

## Part 1: Annotated Email Specimen Analysis

### Specimen 01: Urgent Banking KYC Suspension Lure

**ANNOTATED CAPTURE #01 — SANITIZED INBOX VIEW** **STATUS: QUARANTINED**

**From:** HDFC NetBanking Alert <alerts@hdfc-kyc-verification.xyz> (1)

**To:** [redacted] (Personal details redacted)

**Subject:** ACTION REQUIRED: Your HDFC Account Will Be Suspended Today! (2)

Dear Valued Customer, (3)

Our automated compliance system detected that your PAN and Aadhaar KYC details have expired. Under RBI rules, your account and UPI services will be **permanently blocked within 4 hours** unless you complete instant verification.

**Complete KYC Verification Now** (4)

Please keep your **Debit Card number, ATM PIN, and registered mobile OTP** ready to confirm ownership. (5)

```
[Link Hover Preview]: http://hdfc-kyc-verification.xyz/login/otp-capture.php
(Unencrypted HTTP)
```

- **[1] Spoofed Sender Domain:** The display name claims to be *HDFC NetBanking Alert*, but the actual sending domain is `hdfc-kyc-verification.xyz` rather than the legitimate `hdfcbank.com` domain.
- **[2] Artificial Urgency & Threat:** Threatening permanent account suspension within four hours pressures the recipient into acting emotionally rather than verifying the claim.
- **[3] Generic Salutation:** Addresses the recipient as *"Dear Valued Customer"* instead of using the account holder's registered name.
- **[4] Malicious Unencrypted Link:** Hovering over the action button exposes an unencrypted `http://` URL hosted on a suspicious `.xyz` top-level domain pointing to a credential-harvesting script.

- **[5] Request for Restricted Credentials:** Explicitly asks for an ATM PIN and OTP. Legitimate banks never request PINs, passwords, or OTPs via email.

> **Verdict: PHISHING** — Credential-harvesting attack impersonating a financial institution. **Action Taken:** Did not click the link; reported as phishing to the bank's official fraud desk and deleted the message.

### Specimen 02: Fake Cloud Storage Quota & Password Reset

**ANNOTATED CAPTURE #02 — SANITIZED INBOX VIEW** **STATUS: QUARANTINED**

**From:** Microsoft 365 Admin <support@micros0ft-mail-security.com> (1)
**To:** [redacted] (Personal details redacted)
**Subject:** [Final Warning] 14 Incoming Emails Held — Mailbox Full

Attention User, (2)

Your corporate mailbox has reached 99.8% capacity. As a result, **14 important business messages are currently quarantined** and will be permanently erased at 18:00 today. (3)

**Release Held Messages & Upgrade Quota** (4)

Note: Kindly re-authenticate with your current network password to sync your inbox folders. (5)

```
[Link Hover Preview]: https://bit.ly/3x9FakeM365Auth → redirects to
http://198.51.100.42/owa/login
```

- **[1] Typosquatted Look-Alike Domain:** Uses a zero instead of the letter "o" in `micros0ft-mail-security.com` to deceive rapid visual scanning.
- **[2] Impersonal Greeting:** Uses *"Attention User"* with no reference to the employee's actual name or organization tenant.
- **[3] Fear of Data Loss:** Claims 14 incoming business emails will be deleted at 18:00 to exploit workplace anxiety over missed communications.
- **[4] Obfuscated Shortened URL:** Uses a URL shortener (`bit.ly`) to mask a raw IP address destination (`198.51.100.42`) hosting a fake Outlook Web App login page.
- **[5] Direct Password Solicitation:** Instructs the user to enter their corporate network password on an external page.

> **Verdict: PHISHING** — Enterprise credential-harvesting lure targeting Microsoft 365 accounts. **Action Taken:** Verified mailbox storage directly via official webmail settings, reported to IT Security, and purged from inbox.

## Specimen 03: Fraudulent Courier Delivery Fee & Malware Attachment

**ANNOTATED CAPTURE #03 — SANITIZED INBOX VIEW** **STATUS: QUARANTINED**

**From:** DHL Express Dispatch <dhl.tracking.notice99@gmail.com> (1)
**To:** [redacted] (Personal details redacted)
**Subject:** Parcel #IN-884920 Delivery Failed — Customs Clearance Required
**Attachment:** `Delivery_Receipt_IN884920.zip` (412 KB) (2)

Hello Customer, (3)

We attempted to deliver your international package today, but no one was available and a nominal customs handling charge of ₹49.00 remains unpaid. If you do not pay within 12 hours, the parcel will be returned to sender and a daily storage penalty will apply. (4)

Open the attached shipping manifest or **Pay ₹49.00 Customs Fee** to reschedule delivery. (5)

`[Link Hover Preview]: http://dhl-express-india-track.info/pay/card-details.html`

- **[1] Free Webmail Provider Spoofing:** Claims to be DHL Express Dispatch but is sent from a free consumer Gmail address (`@gmail.com`) rather than `@dhl.com`.
- **[2] High-Risk Archive Attachment:** Includes an unsolicited `.zip` archive, a common delivery vehicle for Trojan droppers and ransomware payloads.
- **[3] Generic Greeting & Unsolicited Shipment:** Uses *"Hello Customer"* and references a random tracking number without listing any sender or recipient address.
- **[4] Low-Value Financial Bait:** Requests a tiny fee (₹49.00) to lower the victim's guard while capturing full credit/debit card details and CVV on the linked form.
- **[5] Rogue Look-Alike Payment Link:** Points to an unencrypted third-party domain (`dhl-express-india-track.info`) instead of the official tracking portal.

**Verdict: PHISHING** — Dual-threat attack combining card-skimming and a malicious archive attachment.
**Action Taken:** Did not extract the ZIP file or click the payment link; reported and permanently deleted.

## Specimen 04: Authentic E-Commerce Order Confirmation

**ANNOTATED CAPTURE #04 — SANITIZED INBOX VIEW** **STATUS: VERIFIED SAFE**

**From:** Amazon.in <auto-confirm@amazon.in> (1)
**To:** [redacted] (Personal details redacted)
**Subject:** Your Amazon.in order #404-7192834-1102938 of 1 item

Hello [redacted], (2)

Thank you for shopping with us. We will send a confirmation when your item ships. Your estimated delivery date is indicated below.

**Order Details:** Logitech Wireless Mouse M185 — Paid via UPI (₹599.00) (3)

**View or Manage Order** (4)

*Note: For your security, Amazon never asks for your password, UPI PIN, or OTP via email.* (5)

```
[Link Hover Preview]: https://www.amazon.in/gp/css/order-details?orderID=404-7192834-1102938
```

- **[1] Verified Official Sender Domain:** Sent directly from `auto-confirm@amazon.in`, matching the official Indian storefront domain with valid SPF/DKIM authentication.
- **[2] Personalized Greeting:** Addresses the customer by their exact registered account name rather than a generic placeholder.
- **[3] Accurate Transaction Context:** Reflects a genuine recent purchase, exact item name, and payment method already completed by the user.
- **[4] Encrypted Official Destination URL:** Hovering reveals an encrypted `https://www.amazon.in/` path leading directly to the legitimate order-management section.
- **[5] Zero Credential Requests:** Informational receipt only; asks for no passwords, OTPs, or payment re-entry.

> **Verdict: SAFE (GENUINE)** — Legitimate transactional order receipt. **Action Taken:** Safe to retain for purchase records; no remediation required.

## Specimen 05: Official Version Control Security Notification

**ANNOTATED CAPTURE #05 — SANITIZED INBOX VIEW** **STATUS: VERIFIED SAFE**

**From:** GitHub <noreply@github.com> (1)
**To:** [redacted] (Personal details redacted)
**Subject:** [GitHub] A new SSH public key was added to your account

Hey @[redacted]! (2)

A new SSH key (`SHA256:9xK4mP2vL8qR7wN1zT5bJ0cF3hY6dG8sA4eU2iO9pQ0`) was recently added to your GitHub account on 12 Nov 2026 at 14:15 UTC. (3)

If you added this key, you can safely ignore this email. If you do not recognize this activity, please visit your account security settings directly on GitHub to revoke the key and review your audit log. (4)

Official Security Documentation: **Review SSH Keys in Settings** (5)

```
[Link Hover Preview]: https://github.com/settings/keys (Valid TLS Certificate)
```

- **[1] Legitimate Domain & Header Alignment:** Sent from `noreply@github.com` with no domain misspellings or third-party relay anomalies.
- **[2] Account-Specific Handle:** Greets the user using their exact GitHub username.
- **[3] Verifiable Audit Metadata:** Provides the exact cryptographic SSH key fingerprint and timestamp matching the user's own workstation setup.
- **[4] Non-Coercive Guidance:** Calm, factual tone advising the user to ignore the notice if expected, without artificial deadlines or panic triggers.
- **[5] Authentic HTTPS Destination:** Hovering confirms the link resolves strictly to `https://github.com/settings/keys`.

> **Verdict: SAFE (GENUINE)** — Legitimate automated security audit alert triggered by user action. **Action Taken:** Confirmed SSH fingerprint matched local machine; archived safely.

## Part 2: Phishing Warning Sign Checklist

Use the seven-point inspection matrix below to evaluate any unexpected message before interacting with links or attachments:

| Inspection Indicator | Phishing Red Flag | Genuine Baseline |
|---|---|---|
| **1. Sender Address** | Display name impersonates a brand, but the domain after @ has typos (`microsOft`), odd extensions (`.xyz`, `.info`), or free webmail (`@gmail.com`). | Exact match to the organization's official domain (e.g., `@amazon.in`, `@github.com`). |
| **2. Urgency & Tone** | Threatens immediate account closure, legal action, or data deletion within hours to induce panic. | Calm, informative language without coercive countdowns or intimidation. |
| **3. Salutation / Greeting** | Generic openings such as *"Dear Customer"*, *"Dear User"*, or *"Attention Member"*. | Uses your full registered name or verified account username. |
| **4. Hyperlinks & URLs** | Hover preview reveals mismatched domains, URL shorteners (`bit.ly`), raw IP addresses, or unencrypted `http://`. | Hover preview shows encrypted `https://` on the exact official domain. |
| **5. Credential Requests** | Asks you to enter or reply with passwords, ATM PINs, CVV numbers, or one-time passwords (OTPs). | Never requests passwords, PINs, or OTPs over email. |

| Inspection Indicator | Phishing Red Flag | Genuine Baseline |
|---|---|---|
| **6. Attachments** | Unexpected `.zip`, `.exe`, `.iso`, or macro-enabled documents claiming to be invoices or delivery slips. | No unexpected executables or archives; receipts appear inline in message text. |
| **7. Grammar & Visuals** | Awkward phrasing, inconsistent fonts, currency mismatches, or pixelated company logos. | Consistent branding, clean typography, and accurate transaction details. |

## Part 3: Safe Incident Reporting Process

When a suspicious or confirmed phishing email enters an inbox, follow this five-step containment protocol:

1. **Stop & Do Not Interact:** Do not click any links, download or extract attachments, reply to the sender, or forward the message to colleagues as a joke.
2. **Verify Out-of-Band:** If the message claims an issue with your bank, courier, or work account, open a fresh browser window, manually type the official website address (or call the number on the back of your bank card), and check your account independently.
3. **Report Through Official Channels:**
   - *Workplace / Organizational Email:* Click the email client's built-in **Report Phishing** button or forward the suspicious message as an attachment (`.eml`) to the IT Security Desk.
   - *Personal / Financial Phishing:* Report the sender to your email provider, notify the impersonated bank's official fraud reporting email, and submit the URL/headers to national cybercrime authorities (such as **CERT-In** / **cybercrime.gov.in**).
4. **Delete Permanently:** Once reported, delete the email from your Inbox and empty your Trash/Deleted Items folder so it cannot be clicked accidentally later.
5. **Warn Peers & Team Members:** Alert teammates, friends, or family members if an active phishing campaign is targeting your organization or region.

### SPOT THE PHISH: 5-SECOND EMAIL SAFETY GUIDE

Quick-Reference Staff Awareness Handout • Think Before You Click

Cybercriminals use deceptive emails to steal passwords, bank details, and company data. Before clicking any link or opening any attachment, inspect these **five critical warning signs**:

| # | Warning Sign | How to Spot It & Stay Safe |
|---|---|---|
| 01 | **Inspect the Real Sender Address** | Never trust the display name alone. Click or expand the sender header to inspect the domain after the @ symbol. Watch for subtle misspellings (such as `@microsOft-security.com` instead of `@microsoft.com`) or free Gmail/Yahoo addresses pretending to be banks or couriers. |
| 02 | **Hover Over Links Before Clicking** | Rest your mouse cursor over buttons and hyperlinks (or press and hold on mobile) without clicking to preview the true destination URL. If the web address uses `http://`, a URL shortener, or an unfamiliar domain, do not click. |
| 03 | **Reject Artificial Urgency & Threats** | Attackers manufacture panic with phrases like *"Account suspended today"*, *"Final warning"*, or *"Unpaid customs fee"* to rush your judgment. Pause and verify any urgent claim by visiting the official website directly in a new browser tab. |
| 04 | **Never Share Passwords, PINs, or OTPs** | Legitimate banks, IT administrators, and service providers will **never** ask for your password, ATM PIN, card CVV, or SMS/app OTP via email. Any email requesting secret credentials is a guaranteed scam. |
| 05 | **Question Generic Greetings & Files** | Mass phishing campaigns typically open with *"Dear Valued Customer"* instead of your real name and often attach unexpected `.zip` or `.exe` files. Never open unsolicited attachments from unknown senders. |

### What To Do If You Suspect a Phishing Email

- **Do NOT click links, download files, or reply** to the sender—even to unsubscribe.
- **Do NOT forward the email** to coworkers as a joke, which spreads malicious links further.
- **If you already clicked or entered a password:** Immediately disconnect from the network, change your password from a clean device, enable Multi-Factor Authentication (MFA), and notify IT Security right away.

**THE 3-STEP INCIDENT RULE: 1. REPORT TO IT / OFFICIAL SUPPORT → 2. DELETE PERMANENTLY → 3. WARN YOUR TEAM**